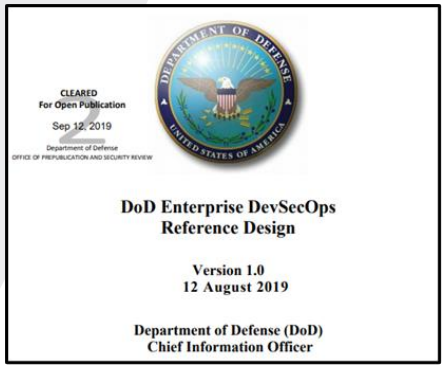
Integrating DevSecOps metrics with CI/CD

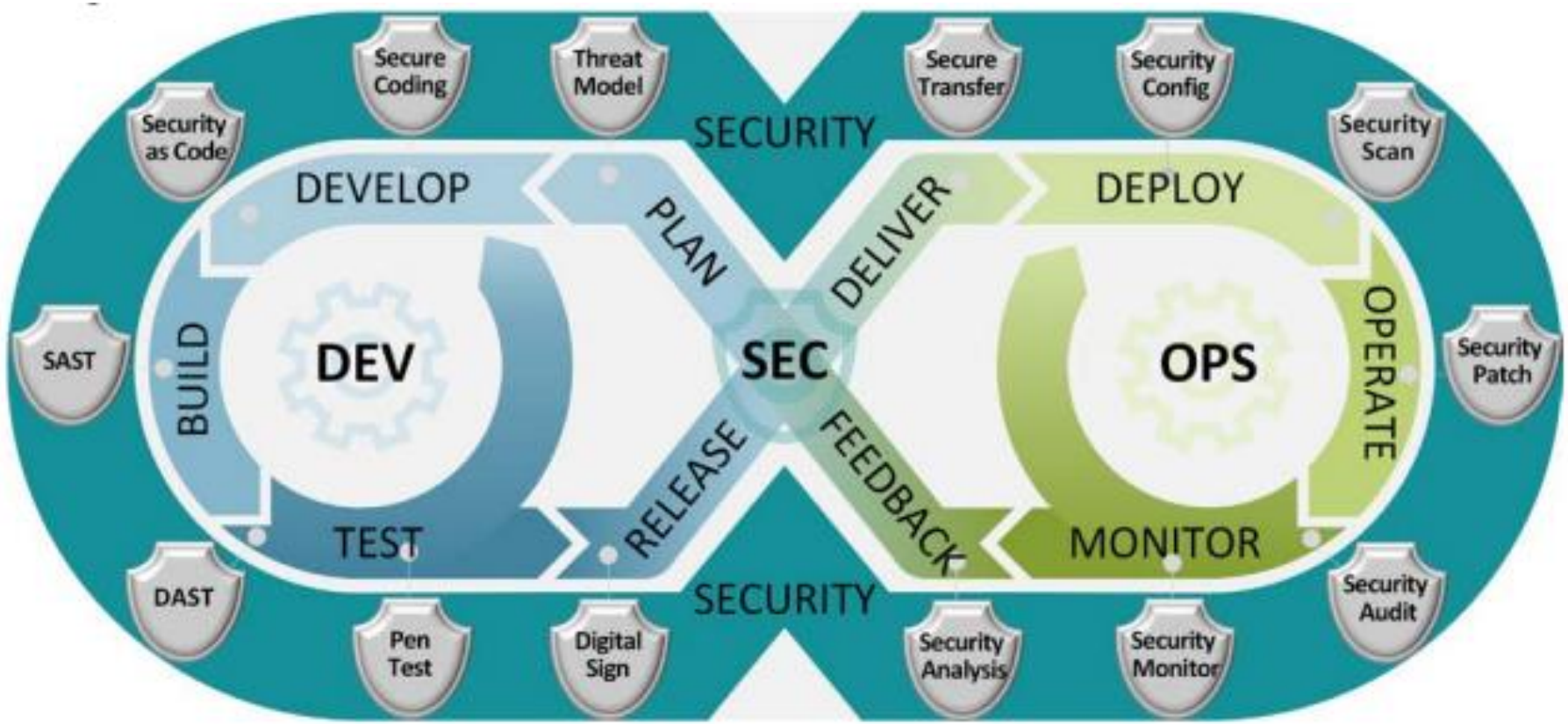
DoD enterprise DevSecOps reference design


CLEARED
For Open Publication
Sep 12, 2019
Department of Defense
OFFICE OF PREPUBLICATION AND SECURITY REVIEW

DoD Enterprise DevSecOps
Reference Design

Version 1.0
12 August 2019

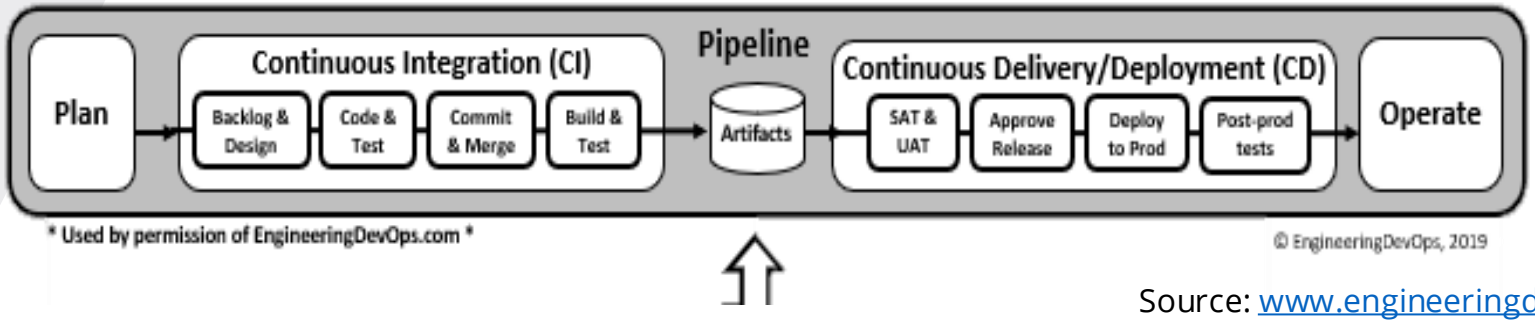
Department of Defense (DoD)
Chief Information Officer



Source:
https://dodcio.defense.gov/Portals/0/Documents/DoD%20Enterprise%20DevSecOps%20Reference%20Design%20v1.0_Public%20Release.pdf

Copyright© 2025 PeopleCert International Ltd.

DevSecOps pipeline attributes

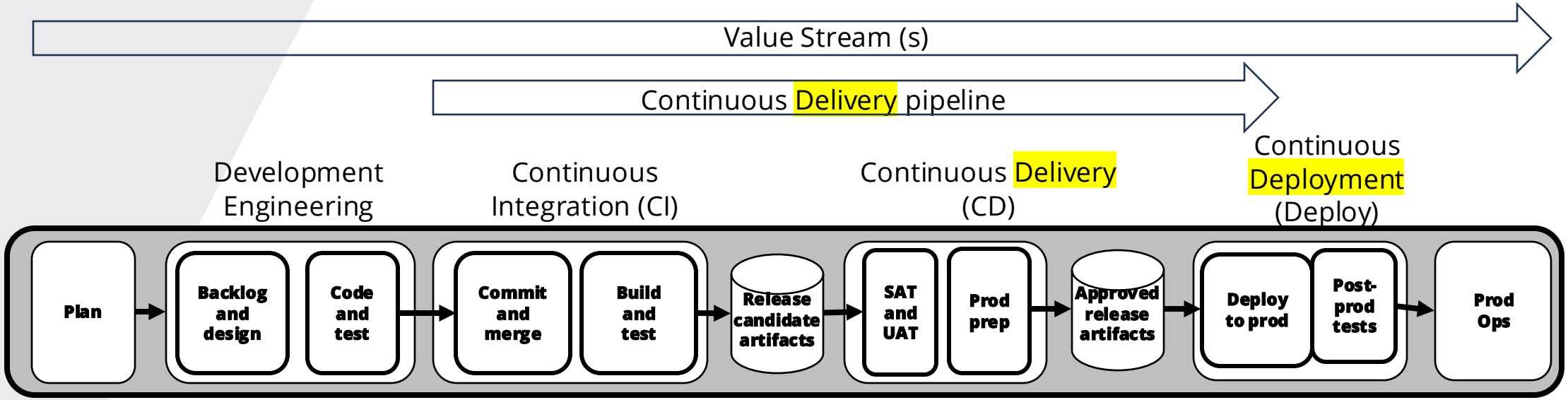


Source: www.engineeringdevops.com

- DevOps is built around pipelines.
- Tools can manage the pipeline:
  - Gitlab
  - Jenkins
  - Circle CI.
- Pipelines integrate multiple tools to check stages.
- Pipeline Tech should:
  - be scalable
  - be trainable
  - offer support
  - have an integrated user community.
- Avoid vendor lock-in, vendor agnostic.

Copyright© 2025 PeopleCert International Ltd.

DevSecOps ‘CI/CD’ explained



Elastic Deployments ‘as Code’ to ‘elastic’ ephemeral ‘cloud’ environments

Development environments

Integration environments

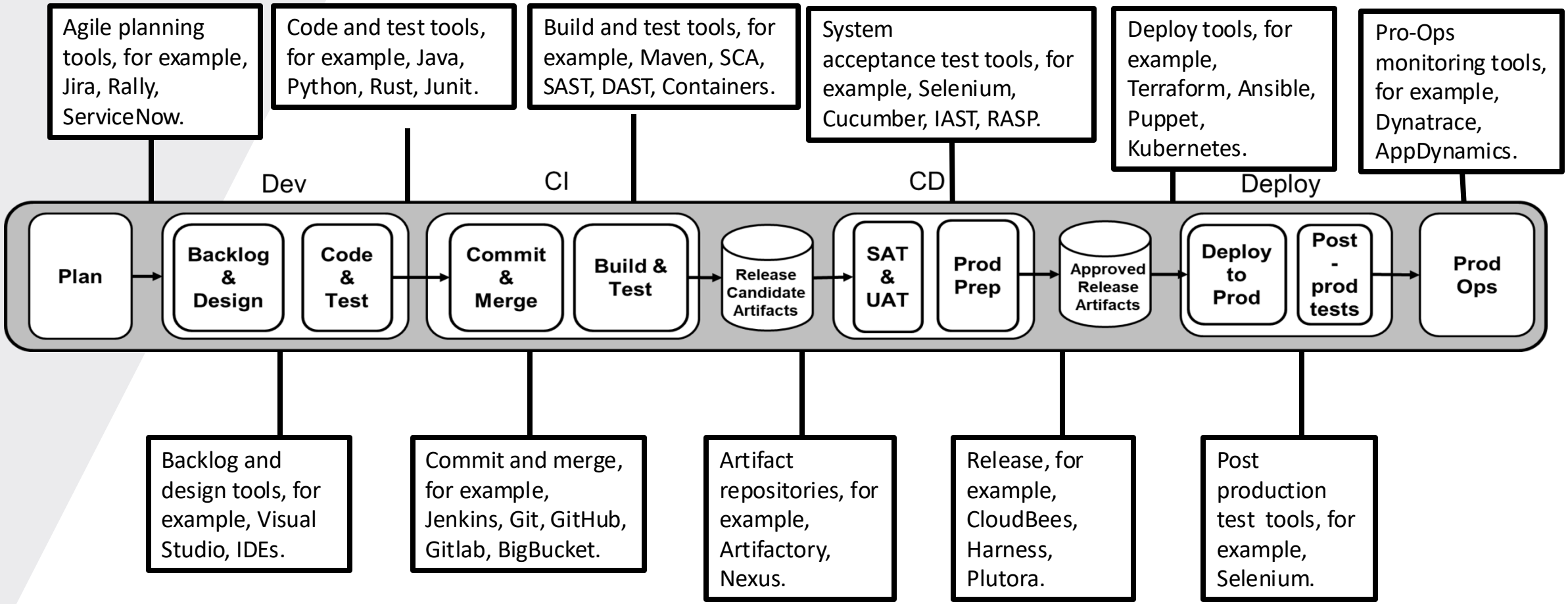
Test environments

Production environments

Source: *Engineering DevOps by Marc Hornbeek*
https://mybook.to/engineeringdevops

Copyright© 2025 PeopleCert International Ltd.

DevSecOps CI/CD pipeline toolchain



Source: *Engineering DevOps by Marc Hornbeek*
https://mybook.to/engineeringdevops

Copyright© 2025 PeopleCert International Ltd.

Common DevSecOps tools

sonatype

Checks a code against the known vulnerabilities in the OSS Index with recommendations on how to proceed.

Nexus Lifecycle

Scans application binaries for known vulnerabilities in open-source libraries.

FORTIFY

Static Application Security Testing (SAST) offering used by development groups and security professionals to analyze the source code for security vulnerabilities.

sonarqube

Open-source platform static analysis of code to detect bugs, code smells, and security vulnerabilities on 20+ programming languages.

Jenkins

Open-source automation server for software building, testing, and deploying, facilitating continuous integration and continuous delivery.

Twistlock

Rule-based access control policy system for Docker and Kubernetes containers.

Jira

Issue tracking product developed by Atlassian that allows bug tracking and agile project management.

CONTRAST SECURITY

Embedding code analysis and attack prevention directly into software.

aqua

Check your container images for vulnerabilities.

OWASP ZAP

Open-source web application security scanner.

FindBugs™

Static analysis looks for bugs in Java code.

GAUNTLT

Automation framework to run things and validate results.

DEPENDENCY-CHECK

Software Composition Analysis (SCA) tool that attempts to detect publicly disclosed vulnerabilities contained within a project's dependencies.

Nessus vulnerability scanner

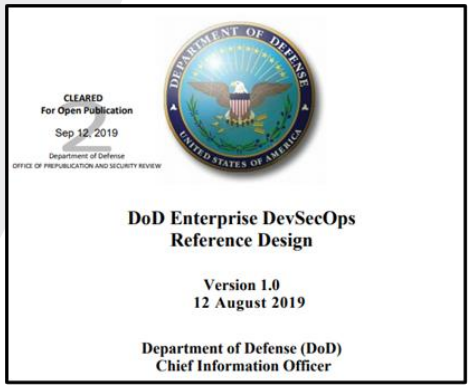
Remote security scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network.

ThreadFix

Aggregating vulnerability test results from static (SAST), dynamic (DAST), and interactive (IAST) application security scanning scanners.

Copyright© 2025 PeopleCert International Ltd.

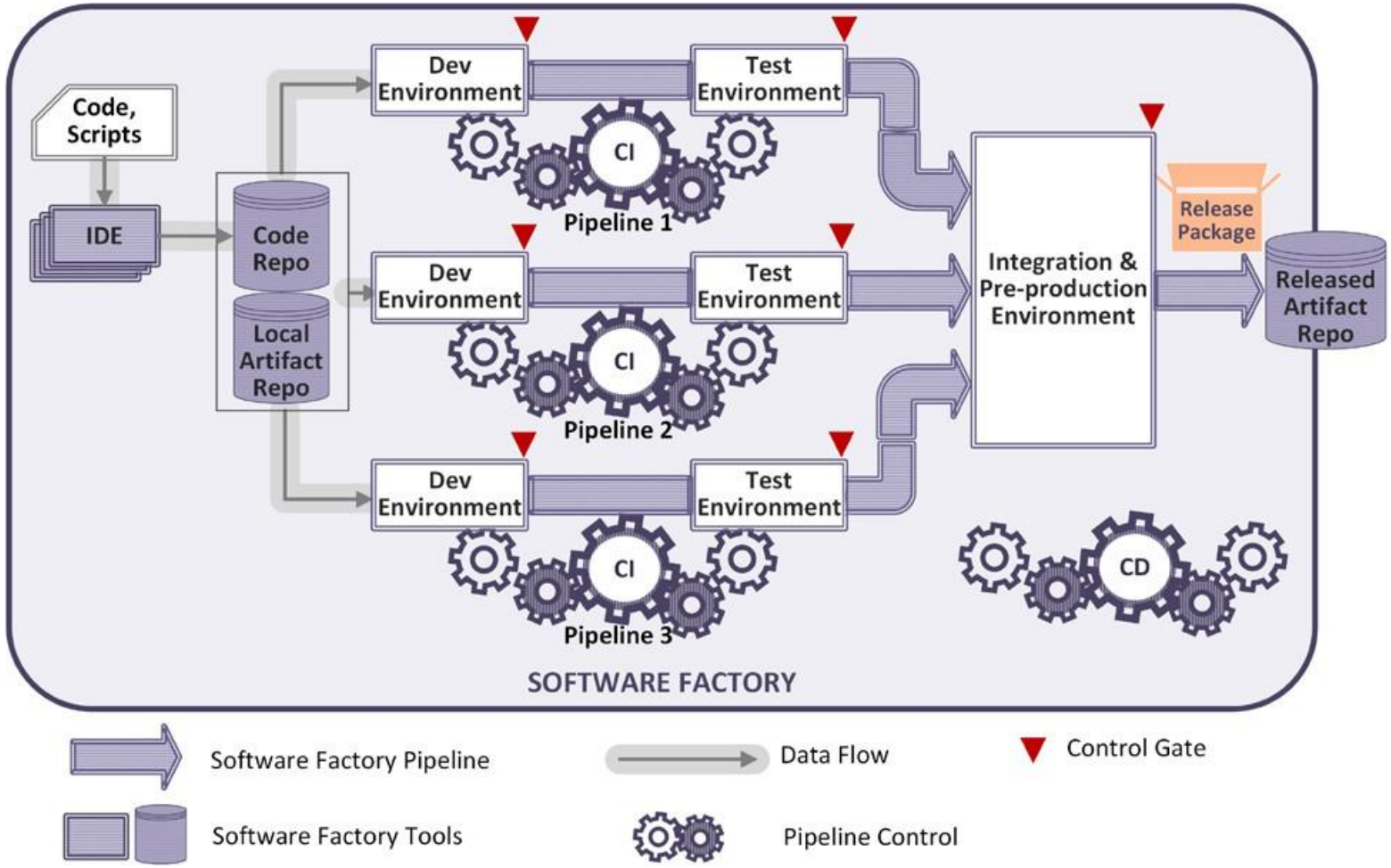
DoD enterprise DevSecOps software factory


CLEARED
For Open Publication
Sep 12, 2019
Department of Defense
OFFICE OF PREPUBLICATION AND SECURITY REVIEW

DoD Enterprise DevSecOps
Reference Design

Version 1.0
12 August 2019

Department of Defense (DoD)
Chief Information Officer



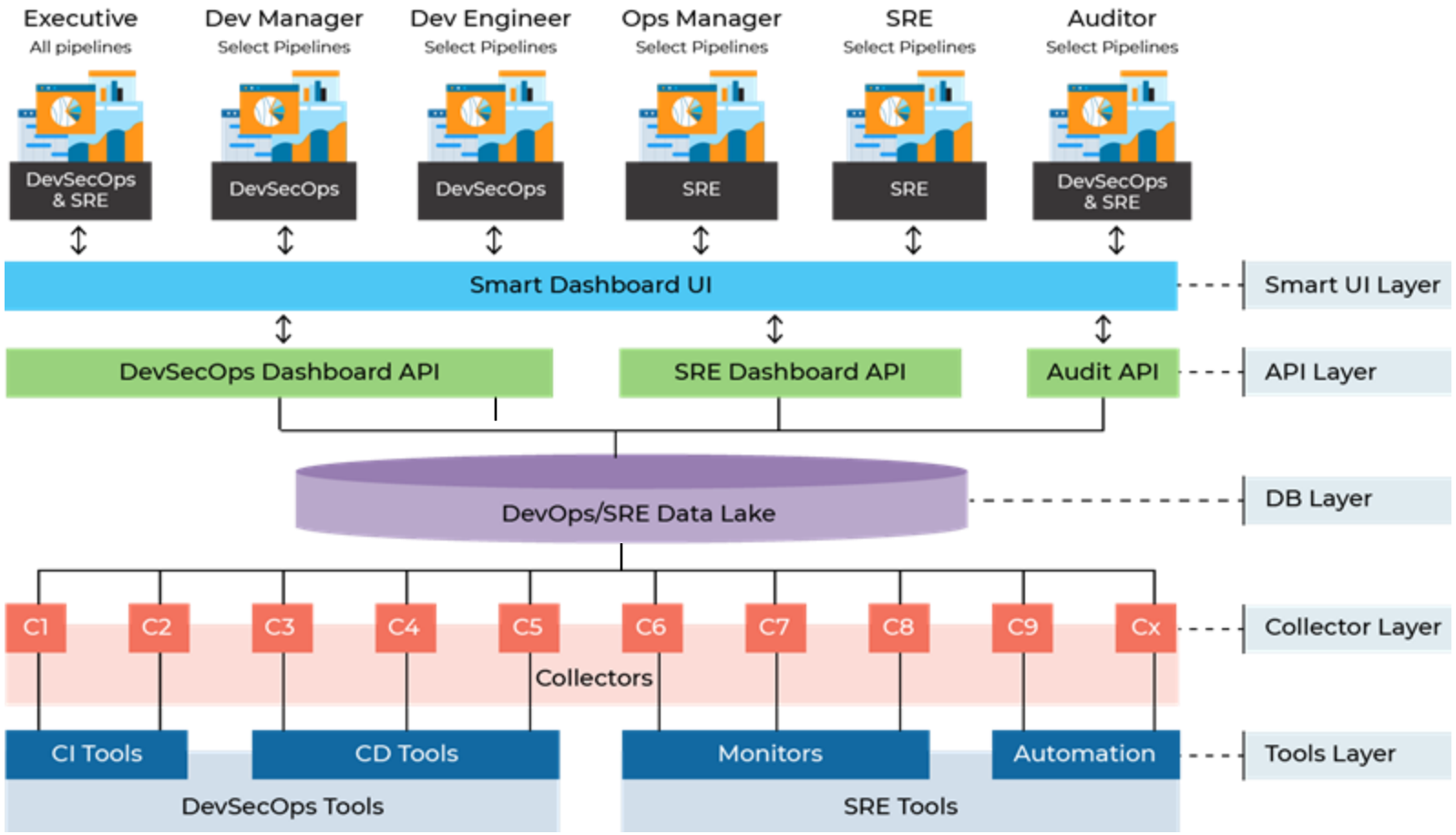
Source:
https://dodcio.defense.gov/Portals/0/Documents/DoD%20Enterprise%20DevSecOps%20Reference%20Design%20v1.0_Public%20Release.pdf

Copyright© 2025 PeopleCert International Ltd.

DevSecOps dashboard implemented with VSM platform



Source:
https://www.plutora.com/resources/value-stream-management-ideal-framework-devsecops-continuous-security

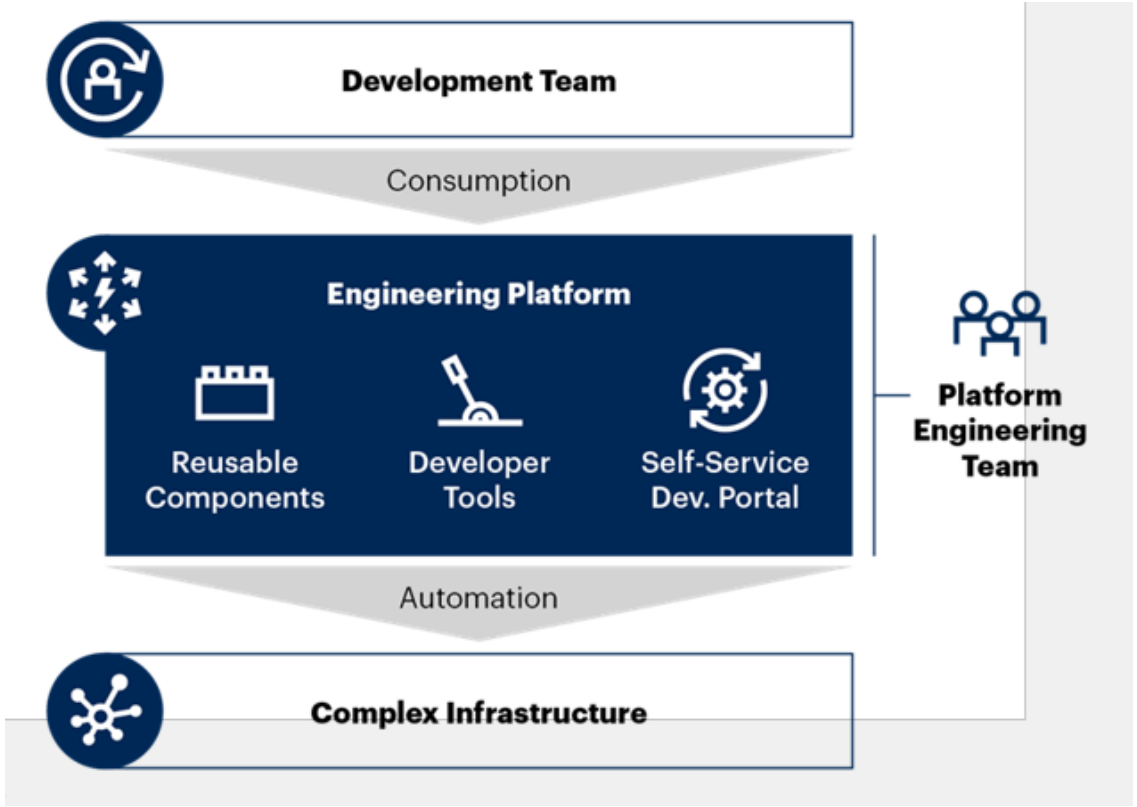


Copyright© 2025 PeopleCert International Ltd.

Platform engineering

Key benefits of platform engineering for DevSecOps:

- **Scalability:** centralized platforms scale security practices across multiple teams and projects.
- **Consistency:** ensures standardized security measures are applied uniformly.
- **Developer enablement:** empowers developers to own security without deep expertise.
- **Speed and agility:** balances speed with security by automating manual processes.
- **Proactive security:** enables real-time monitoring and rapid remediation.



Source: https://cote.io/2022/02/14/platform-engineering-probably.html

Copyright© 2025 PeopleCert International Ltd.

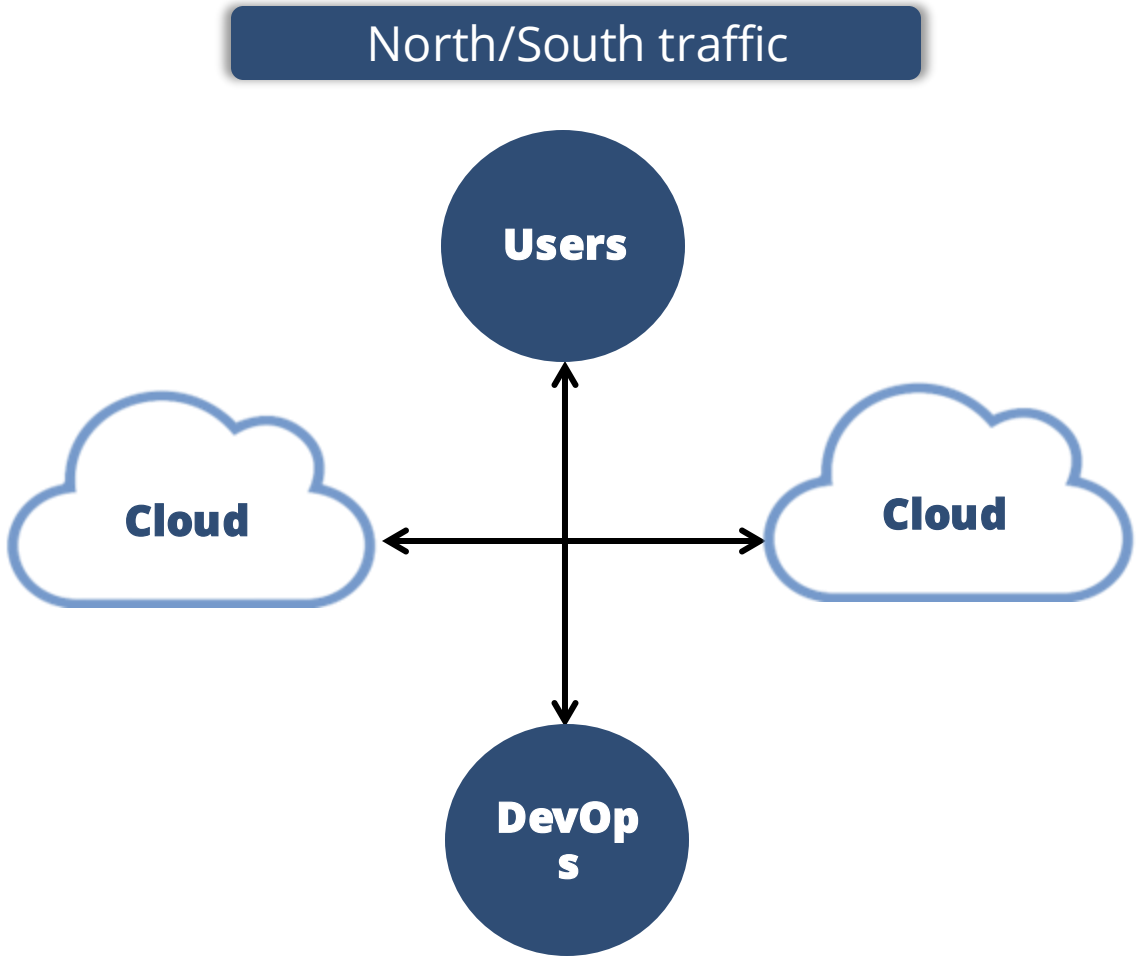
Challenges for metric implementation

Challenges to technical views

- multi-cloud environments
- microservices
- volume, velocity, variety of alerting
- siloed infrastructure.

Challenges to teams

- business values
- remote teams
- lack of shared environments.



Copyright© 2025 PeopleCert International Ltd.